

Guide d'utilisation de l'outil d'évaluation de la maturité SSI

Projet TER — Évaluation du niveau de maturité SSI en Cybersécurité

Ce guide présente le fonctionnement de l'outil d'évaluation de maturité SSI, les différents référentiels utilisés, la méthode de sélection des niveaux de maturité ainsi que l'interprétation des résultats via les tableaux de bord.

Réalisé par :

LAMROUS Anis Abraham
BENMIMOUN Yanis
BAKHELAL Nabil
JEGOU Mathieu
RAFAEL Paola
DABO Ibrahim

Encadré par : Mme. DJOUDI Chahinda Ferial

Année universitaire : 2025–2026

Présentation globale de l'outil

L'outil permet d'évaluer le niveau de maturité SSI d'une organisation à partir de plusieurs cadres de référence en cybersécurité. Il regroupe quatre référentiels principaux :

- Le guide d'hygiène informatique de l'ANSSI
- DORA
- NIS2
- Les CIS Controls

Chaque référentiel est présenté dans une feuille dédiée. L'utilisateur peut sélectionner un niveau de maturité pour chaque exigence, ajouter un commentaire, puis consulter les résultats dans les tableaux de bord associés.



Historique des révisions

VERSION	DATE	AUTEUR(S)	RÉSUMÉ DES MODIFICATIONS
V1.0.0	25/05/2026	BAKHELAL Nabil JEGOU Mathieu	Mise en Page
V1.0.1	27/05/2026	BENMIMOUN Yanis DABO Ibrahim RAFAEL Paola	Validation du document

Approbation

NOM	FONCTION	DATE
Mme DJOUDI Chahinda	Encadrante	30/06/2026
BAKHELAL Nabil	Membre du groupe TER	27/06/2026
BENMIMOUN Yanis	Membre du groupe TER	26/06/2026
DABO Ibrahim	Membre du groupe TER	28/06/2026
JEGOU Mathieu	Membre du groupe TER	27/06/2026
LAMROUS Anis Abraham	Membre du groupe TER	27/06/2026
RAFAEL Paola	Membre du groupe TER	27/06/2026

Organisation générale des feuilles

L'outil est structuré en plusieurs types de feuilles. Les feuilles de référentiel contiennent les exigences à évaluer. Elles permettent de consulter les règles, descriptions, preuves attendues, fonctions de sécurité et niveaux de maturité. Les feuilles Dashboard permettent de visualiser les résultats sous forme de graphiques, scores et statistiques. La feuille Échelle de maturité sert de référence pour comprendre la signification des niveaux utilisés dans l'évaluation.

1 Chapitres	2 ID	3 Règle de bonnes pratiques	4 Description de la règle	5 Description intégrale	6 Type d'actifs	7 Preuves attendues	8 Niveau de maturité	9 Commentaire
Grand thème ou domaine de sécurité concerné.	Numéro unique de la règle pour l'identifier facilement.	Intitulé court de la bonne pratique à évaluer.	Explication courte de ce qui est attendu.	Accès au détail complet de la règle.	Éléments concernés : données, systèmes, réseaux, applications, etc.	Documents ou éléments à fournir pour justifier l'évaluation.	Niveau attribué pour évaluer l'état actuel de l'organisation.	Zone libre pour ajouter remarques, justifications ou pistes d'amélioration.
Chapitres	ID	Règle de bonnes pratiques	Description de la règle	Description intégrale	Type d'actifs	Preuves attendues	Niveau de maturité	Commentaire
SENSIBILISER ET FORMER	1	Former les équipes opérationnelles à la sécurité des systèmes d'information	Les équipes opérationnelles disposent d'accès privilégiés devant être formés à la sécurité des systèmes d'information dès leur prise de fonction. Ces formations doivent être de chaque métier afin de limiter les risques liés à une mauvaise manipulation.	Voir règle	Identité et accès, Systèmes d'exploitation, Réseaux, Logiciels	Politique ou plan de formation SSI, registres des formations réalisées, attestations de participation, rapports de formation, clauses de formation SSI dans les contrats.	2 - Émergent	Lire zone de commentaire et d'évaluation de chaque critère pour l'organisation et une série de notes en place des premières mesures opérationnelles.
	2	Sensibiliser les utilisateurs aux bonnes pratiques élémentaires de sécurité informatique	Tous les utilisateurs doivent être sensibilisés dès leur arrivée aux enjeux de sécurité et aux règles de bon usage du système d'information. Ces actions doivent être régulières et adaptées en fonction des menaces et évolutions des risques liés aux comportements humains.	Voir règle	Identité et accès, Matériels, Systèmes d'exploitation	Programme de sensibilisation SSI, supports de communication, listes de diffusion, affiches, quiz/campagnes de tests, retours des campagnes internes de sensibilisation, statistiques de participation.	5 - Optimal	Des objectifs de réduction des risques cyber stratégiques à l'organisation. Connaissance. Des mesures formalisées, suivies, et pilotées pour une maturité adaptative et mesurable.
	3	Maîtriser les risques de l'infogérance	L'externalisation ou la sous-traitance doit être précédée d'une analyse de risques SSI afin d'identifier les exigences de sécurité à imposer au prestataire. Ces exigences doivent être formalisées contractuellement pour garantir la maîtrise, la traçabilité et le maintien du niveau de sécurité.	Voir règle	Données, Services, Applications, Infrastructure	Analyse de risques SSI, cahier des charges de sécurité, contrats avec clauses SSI, plan d'assurance sécurité signé, rapports de revue/audit et de révision des données.	5 - Optimal	Des objectifs de réduction des risques cyber stratégiques à l'organisation. Connaissance. Des mesures formalisées, suivies, et pilotées pour une maturité adaptative et mesurable.
CONNAÎTRE SON ENVIRONNEMENT	4	Identifier les informations et services les plus sensibles et maintenir un schéma de réseau	Les données sensibles doivent être identifiées et localisées dans le système d'information afin de déterminer le niveau de risque associé. Un schéma réseau (logique ou physique) doit être disponible et tenu à jour pour cartographier les flux, les zones réseau et les composants critiques.	Voir règle	Données, Matériels, Réseaux, Systèmes d'exploitation	Registre des données sensibles, cartographie réseau à jour, schéma d'architecture, inventaire des actifs, revues documentaires, tests de vérification.	3 - Intermédiaire	Une connaissance partagée des risques cyber pour l'organisation et la sécurité de formaliser les premiers contrôles sur les systèmes et l'environnement tout en ajustant les pratiques.
	5	Disposer d'un inventaire exhaustif des comptes privilégiés et le maintenir à jour	Les comptes disposant de droits élevés doivent être inventoriés et maintenus à jour afin de limiter les risques d'abus ou de compromission. Une revue régulière des droits permet de supprimer les accès obsolètes et de garantir la maîtrise des privilèges.	Voir règle	Identité et accès, Systèmes d'exploitation, Applications, Données	Intendaire des comptes à privilèges, registre des comptes d'identifiants et actifs, comptes, production des revues périodiques des droits, comptes, audit des revues d'habilitation, règles de nomenclature des comptes.	Non Applicable	Le critère ou l'exigence évalué n'est pas pertinent des activités, du périmètre technique ou du cadre réglementaire de l'organisation.

Référentiels : Guide d'hygiène informatique de l'ANSSI

La feuille Guide d'hygiène informatique de l'ANSSI présente les bonnes pratiques issues du guide de l'ANSSI. Chaque ligne correspond à une règle ou une mesure de sécurité. Les règles sont regroupées par chapitre afin de faciliter la lecture. L'utilisateur peut consulter la description de la règle, choisir un niveau de maturité, lire la signification associée et ajouter un commentaire si nécessaire.

1 Chapitres	2 ID	3 Règle de bonnes pratiques	4 Description de la règle	5 Description intégrale	6 Type d'actifs	7 Preuves attendues	8 Niveau de maturité	9 Commentaire
Grand thème ou domaine de sécurité concerné.	Numéro unique de la règle pour l'identifier facilement.	Intitulé court de la bonne pratique à évaluer.	Explication courte de ce qui est attendu.	Accès au détail complet de la règle.	Éléments concernés : données, systèmes, réseaux, applications, etc.	Documents ou éléments à fournir pour justifier l'évaluation.	Niveau attribué pour évaluer l'état actuel de l'organisation.	Zone libre pour ajouter remarques, justifications ou pistes d'amélioration.
Chapitres	ID	Règle de bonnes pratiques	Description de la règle	Description intégrale	Type d'actifs	Preuves attendues	Niveau de maturité	Commentaire
SENSIBILISER ET FORMER	1	Former les équipes opérationnelles à la sécurité des systèmes d'information	Les équipes opérationnelles disposent d'accès privilégiés devant être formées à la sécurité des systèmes d'information dès leur prise de fonction. Ces formations doivent être de chaque métier afin de limiter les risques liés à une mauvaise manipulation.	Voir règles	Identité et accès, Systèmes d'exploitation, Réseaux, Logiciels	Politique ou plan de formation SSI, registres des formations réalisées, attestations de participation, rapports de formation, clauses de formation SSI dans les contrats.	2 - Émergent	Libre zone de commentaire et d'évaluation de chaque critère pour l'organisation et une variété de modes en place des premières mesures opérationnelles.
	2	Sensibiliser les utilisateurs aux bonnes pratiques élémentaires de sécurité informatique	Tous les utilisateurs doivent être sensibilisés dès leur arrivée aux enjeux de sécurité et aux règles de bon usage du système d'information. Ces actions doivent être régulières et adaptées en fonction des menaces et évolutions des risques liés aux comportements humains.	Voir règles	Identité et accès, Matériels, Systèmes d'exploitation	Programme de sensibilisation SSI, supports de communication, listes de diffusion, affiches, quiz/campagnes de tests, retours des campagnes internes de sensibilisation, statistiques de participation.	3 - Optimal	Des objectifs de réduction des risques cyber stratégiques l'organisation. Comparaison des mesures formalisées, suivies, et pilotées pour une maturité adaptative et mesurable.
	3	Maîtriser les risques de l'infogérance	L'externalisation ou la sous-traitance doit être précédée d'une analyse de risques SSI afin d'identifier les exigences de sécurité à imposer au prestataire. Ces exigences doivent être formalisées contractuellement pour garantir la maîtrise, la traçabilité et le maintien du niveau de sécurité.	Voir règles	Données, Services, Applications, Infrastructure	Analyse de risques SSI, cahier des charges de sécurité, contrats avec clause SSI, plan d'assurance sécurité signé, rapports de revues/audit et de révision des données.	3 - Optimal	Des objectifs de réduction des risques cyber stratégiques l'organisation. Comparaison des mesures formalisées, suivies, et pilotées pour une maturité adaptative et mesurable.
CONNAÎTRE SON ENVIRONNEMENT	4	Identifier les informations et services les plus sensibles et maintenir un schéma du réseau	Les données sensibles doivent être identifiées et localisées dans le système d'information afin de déterminer le niveau de risque associé. Un schéma réseau (logique ou physique) doit être disponible et tenu à jour pour cartographier les flux, les zones réseau et les composants critiques.	Voir règles	Données, Matériels, Réseaux, Systèmes d'exploitation	Registre des données sensibles, cartographie réseau à jour, schéma d'architecture, inventaire des actifs, revues documentaires, tests de vérification.	3 - Intermédiaire	Une connaissance partagée des risques cyber pour l'organisation et la volonté de formaliser les premiers contrôles sur les systèmes et l'environnement tout en ajustant les pratiques.
	5	Disposer d'un inventaire exhaustif des comptes privilégiés et le maintenir à jour	Les comptes disposant de droits élevés doivent être inventoriés et maintenus à jour afin de limiter les risques d'abus ou de compromission. Une revue régulière des droits permet de supprimer les accès obsolètes et de garantir la maîtrise des privilèges.	Voir règles	Identité et accès, Systèmes d'exploitation, Applications, Données	Identaire des comptes à privilèges, registre des comptes détenus et actifs, comptes, production des revues périodiques des droits, comptes, audit des revues d'habilitation, règles de nomenclature des comptes.	Non Applicable	Le critère ou l'exigence évalué n'est pas pertinent des actifs, des activités, du périmètre technique ou du cadre réglementaire de l'organisation.

Référentiels : DORA

La feuille DORA permet d'évaluer la maturité d'une organisation par rapport aux exigences du règlement DORA. Les exigences sont organisées par grands domaines : dispositions générales, gestion des risques TIC, gestion des incidents TIC, tests de résilience, prestataires tiers TIC, partage d'informations, apprentissage et évolution. Pour chaque exigence, l'utilisateur retrouve une description simple, une description complète, le type d'actif concerné, la fonction sécurité, les preuves attendues et le niveau de maturité sélectionné.

[illegible]

Référentiels : NIS2

La feuille NIS2 permet d'évaluer la maturité d'une organisation face aux exigences liées à la directive NIS2. Elle reprend les principales obligations liées à la cybersécurité : gouvernance, gestion des risques, sécurité des systèmes, gestion des incidents, continuité d'activité, notification, supervision et amélioration. L'utilisateur peut évaluer chaque exigence en choisissant un niveau de maturité, puis suivre les points faibles à améliorer.

1	2	3	4	5	6	7	8
Domaine Grand thème ou catégorie du référentiel concerné.	ID Identifiant unique du contrôle ou de l'exigence.	Exigence / contrôle Intitulé court du point à évaluer.	Description Explication synthétique de ce qui est attendu.	Preuve attendue Documents ou éléments à fournir pour justifier l'évaluation.	Niveau de maturité Niveau attribué pour évaluer l'état actuel de l'organisation.	Description du niveau Interprétation du niveau de maturité sélectionné.	Commentaire / recommandation Zone libre pour remarques, justifications ou actions d'amélioration.
Gouvernance	1	Identifier l'assujettissement NIS2 (secteur, taille, services)	Déterminer si l'entité est concernée et définir le périmètre (entités, sites, services)	Analyse d'implémentation NIS2, cartographie des services critiques, justification écrite des conclusions.	9 - Optimal	Des objectifs de réduction des risques cyber intégrés à la stratégie de l'organisation. Des moyens humains, budgétaires conséquents, un plan d'action cyber exhaustif, adapté aux menaces stratégiques.	Assurer une amélioration continue du processus d'assujettissement NIS2, intégrer les évolutions réglementaires et organisationnelles dans les mécanismes de gouvernance et renforcer les indicateurs de pilotage associés.
	2	Rôles et responsabilités cybersécurité (RSSI, IT, métiers)	Définir qui fait quoi : pilotage, exploitation, validation, escalade.	Organigramme, fiches de poste/lettres de mission, matrice RACI cybersécurité.	3 - Intermédiaire	Une conscience partagée des risques cyber pour l'organisation et la volonté de formaliser un plan d'action cyber complet tout en ajustant les moyens en conséquence.	Compléter les fiches de poste et la matrice RACI, préciser les responsabilités de pilotage, d'exploitation, de contrôle et d'escalade, puis assurer leur diffusion et leur compréhension par les parties prenantes.
	3	Supervision par la direction (pilotage, arbitrages)	La direction suit les risques cyber, valide les priorités et arbitre les budgets.	PV de comité (mensuel/trimestriel), décisions, budget, KPIs/R.	5 - Optimal	Des objectifs de réduction des risques cyber intégrés à la stratégie de l'organisation. Des moyens humains, budgétaires conséquents, un plan d'action cyber exhaustif, adapté aux menaces stratégiques.	Développer une démarche d'amélioration continue fondée sur les indicateurs stratégiques de mesure l'efficacité des mesures émergentes et l'ajustement permanent des investissements cybersécurité avec les objectifs de l'organisation.
	4	PSSI = politiques de sécurité maintenues à jour	Avoir des règles écrites (accès, mots de passe, sauvegardes, incidents...) et s'y conformer.	PSSI, politiques datées, preuve d'approbation direction, preuve de diffusion.	3 - Intermédiaire	Une conscience partagée des risques cyber pour l'organisation et la volonté de formaliser un plan d'action cyber complet tout en ajustant les moyens en conséquence.	Compiler le corpus documentaire afin de couvrir l'ensemble des domaines cybersécurité pertinents, organiser sa diffusion aux collaborateurs concernés et mettre en place un processus de revue annuel périodique documenté.
Gestion des risques	5	Méthode de gestion des risques cyber formalisée	Identifier, évaluer et traiter les risques cyber sur le périmètre NIS2 (SI, services, processus critiques)	Méthodologie ISO 27006 / EBIOS / ... , registre des risques, plan de traitement, revues périodiques, validation.	Non applicable	Le critère de l'exigence évalué n'est pas pertinent au regard des activités, du périmètre technique ou du cadre réglementaire de l'organisation.	Non applicable
	6	Inventaire des actifs (SI, logiciels, services) et propriétaires	Maintenir un inventaire à jour des actifs (logiciels, serveurs, applis, services cloud) et des propriétaires.	Inventaire/CMDR, base logicielle, cartographie, propriétaires d'actifs, fréquence de mise à jour.	4 - Confirmé	Une cartographie précise de ses risques cyber pour l'organisation, un plan d'action cyber approfondi et des moyens humains et budgétaires dédiés.	Maintenir la qualité et l'exactitude de l'inventaire par des revues périodiques, des contrôles réguliers et son intégration avec les processus de gestion des vulnérabilités, des correctifs et des changements.
	7	Classification des données et règles de protection	Identifier les données sensibles et appliquer des règles de protection (accès, stockage, chiffrement).	Politique de classification, registre de données sensibles, règles de stockage/partage, exemples d'étiquetage, contrôles.	9 - Optimal	Des objectifs de réduction des risques cyber intégrés à la stratégie de l'organisation. Des moyens humains, budgétaires conséquents, un plan d'action cyber exhaustif, adapté aux menaces stratégiques.	Optimiser la gouvernance des données par l'actualisation de la classification, le suivi d'indicateurs de conformité et l'actualisation continue des mesures de protection en fonction des risques et des évolutions réglementaires.
	8	Gestion des vulnérabilités (détection, priorisation, correction)	Détecter les vulnérabilités, prioriser selon le risque et corriger dans des délais définis (SLA)	Outils de scan, rapports, tickets, SLA, exceptions approuvées, suivi jusqu'à clôture.	9 - Optimal	Des objectifs de réduction des risques cyber intégrés à la stratégie de l'organisation. Des moyens humains, budgétaires conséquents, un plan d'action cyber exhaustif, adapté aux menaces stratégiques.	Optimiser la gestion des vulnérabilités par l'automatisation des actions et l'indicateur de risque de la priorité, prioriser l'action à l'aide d'indicateurs avancés et adapter en continu les priorités en fonction de l'évolution des menaces et de l'importance des risques.
	9	Patch management (OS, applications, firmwares)	Définir, appliquer et suivre les mises à jour de sécurité sur le périmètre NIS2 (postes, serveurs, équipements réseau, applications, cloud).	Politique de patch management, inventaire des actifs couverts, calendrier de déploiement, tableau de conformité, rapports de déploiement, gestion des exceptions (suppression + durée), preuves de tests si nécessaire.	3 - Intermédiaire	Une conscience partagée des risques cyber pour l'organisation et la volonté de formaliser un plan d'action cyber complet tout en ajustant les moyens en conséquence.	Étendre la gestion des correctifs à l'ensemble des actifs du périmètre (postes de travail, serveurs, équipements réseau, applications et services cloud), formaliser les délais de traitement selon la criticité et assurer le suivi systématique des déploiements.
	10	Gestion du cycle de vie des comptes (arrivée, départ, mobilité)	Créer/modifier/supprimer les comptes de façon contrôlée et rapide.	Procédure IAM, workflow/tickets RH-IT, preuves de suppression	9 - Optimal	Des objectifs de réduction des risques cyber intégrés à la stratégie de l'organisation. Des moyens humains, budgétaires conséquents, un plan	Optimiser la gestion des identités et des accès par l'automatisation des workflows d'intégration entre les systèmes RH et IT, le pilotage

Référentiels : CIS Controls

La feuille CIS Controls présente les contrôles et sous-contrôles issus du référentiel CIS. Ce référentiel est plus opérationnel. Il permet d'identifier des mesures concrètes de sécurité, comme l'inventaire des actifs, la gestion des comptes, la protection des données, la supervision ou la réponse aux incidents. Chaque ligne correspond à un sous-contrôle. L'utilisateur peut consulter sa description, le type d'actif concerné, le groupe de mise en œuvre, la fonction sécurité et le niveau de maturité choisi.

1 Contrôle CIS	2 ID Contrôle	3 ID Mesure	4 Mesure / exigence	5 Description	6 Type d'actifs	7 Fonction de sécurité	8 Groupe (IG)	9 Niveau de maturité	10 Preuves / commentaires	11 Recommandation
Grand domaine ou famille de contrôles CIS concerné.	Identifiant du contrôle principal pour le repérer facilement.	Référence numérique de la mesure ou sous-mesure.	Action précise ou bonne pratique à mettre en œuvre.	Explication synthétique de ce qui est attendu.	Actifs concernés : matériel, logiciel, données, etc.	Objectif du contrôle : identifier, protéger, répondre, etc.	Groupe d'implémentation CIS : IG1, IG2 ou IG3.	Niveau évalué pour mesurer l'état actuel de l'organisation.	Éléments justificatifs, constats ou remarques d'évaluation.	Actions proposées pour améliorer la conformité ou la maturité.
Contrôle CIS	ID Contrôle	ID Mesure	ID Mesure	Description	Type d'actifs	Fonction de sécurité	Groupe (IG)	Niveau de Maturité	Preuves / Commentaires	Recommandation
INVENTAIRE ET CONTRÔLE DES ACTIFS MATÉRIELS	1	1.1	Établir et maintenir un inventaire détaillé des actifs de l'entreprise (matériel, cloud, etc.).	Maintenir un registre à jour de tous les équipements (physiques, virtuels, cloud) connectés à l'entreprise pour savoir ce qui doit être protégé.	Matériel	Identifier	IG 1/2/3	Non applicable	Faire l'inventaire mais mis à jour manuellement une fois par an. Cloud absent.	Mettre en place un outil d'inventaire automatisé (ex: CIS Inventory, GLPI).
	1	1.2	Traiter les actifs non autorisés (les retirer du réseau, les isoler ou les autoriser).	Mettre en place un processus hebdomadaire pour détecter et isoler ou déconnecter tout matériel non autorisé sur le réseau.	Matériel	Répondre	IG 1/2/3	2 - Émergent	Aucun étranger classé en pièce. Les pièces classées sont en accès libre dans les bureaux.	Configurer le port sécurité ou le protocole 802.1x sur les switchs d'accès.
	1	1.3	Utiliser un outil de découverte active pour identifier les actifs connectés.	Exploiter un outil de scan automatique quotidien pour identifier activement tous les appareils connectés au réseau.	Matériel	Identifier	IG 2/3	3 - Confirmé		
	1	1.4	Mettre à jour l'inventaire via l'enregistrement des requêtes DHCP.	Exploiter les journaux des serveurs DHCP pour mettre à jour l'inventaire matériel au moins une fois par semaine.	Matériel	Identifier	IG 2/3	3 - Intermédiaire		
	1	1.5	Utiliser un outil de découverte passive pour identifier les actifs connectés.	Utiliser des outils d'écoute réseau (passive) pour identifier les équipements sans perturber le trafic.	Matériel	Identifier	IG 3	3 - Confirmé		
INVENTAIRE ET CONTRÔLE DES ACTIFS LOGICIELS	2	2.1	Établir et maintenir un inventaire des logiciels autorisés.	Créer et maintenir une liste des logiciels dont l'utilisation est officiellement approuvée dans l'entreprise.	Logiciel	Identifier	IG 1/2/3	3 - Intermédiaire		
	2	2.2	S'assurer que les logiciels autorisés sont toujours supportés.	Vérifier que les logiciels autorisés reçoivent toujours des mises à jour de sécurité de la part de leur éditeur.	Logiciel	Identifier	IG 1/2/3	3 - Confirmé	Une liste des logiciels "validés" existe mais l'outil n'a pas de présence d'outil non autorisé (Chapbon personnel, virus VCL2, etc.).	Configurer l'inventaire avec une solution de contrôle d'accès (Dynt, AppLocker) pour bloquer l'installation des logiciels non validés.
	2	2.3	Traiter les logiciels non autorisés.	Identifier et supprimer ou bloquer tous les logiciels non autorisés qui ne figurent pas dans l'entreprise autorisée.	Logiciel	Répondre	IG 1/2/3	3 - Confirmé		
	2	2.4	Utiliser des outils d'inventaire logiciel automatisés.	Mettre en place un outil d'inventaire logiciel qui interroge automatiquement les applications.	Logiciel	Identifier	IG 2/3	3 - Intermédiaire		
	2	2.5	Autoriser l'installation de logiciels via liste d'autorisation (Allowlisting).	Installer sur le PC des logiciels non approuvés via un système de liste blanche (allowlisting).	Logiciel	Protéger	IG 2/3	3 - Intermédiaire		
	2	2.6	Autoriser l'installation de logiciels via liste d'autorisation.	Installer sur le PC des logiciels non approuvés via un système de liste blanche (allowlisting).	Logiciel	Protéger	IG 3	3 - Confirmé		
	2	2.7	Autoriser l'installation de logiciels via liste d'autorisation.	Installer sur le PC des logiciels non approuvés via un système de liste blanche (allowlisting).	Logiciel	Protéger	IG 3	Non applicable		
PROTECTION DES DONNÉES	3	3.1	Établir et maintenir un processus de gestion des données.	Créer la liste blanche pour contrôler également l'installation des logiciels (ex: .exe, .dll).	Données	Identifier	IG 1/2/3	2 - Émergent	Le traitement des données se fait de manière ad hoc. Aucune politique formelle de classification (Public, Interne, Confidential) ou de durée de conservation.	Tester et faire valider par la direction une politique de classification et de protection de l'information.
	3	3.2	Établir et maintenir un inventaire des données.	Cartographier où sont stockées les données sensibles (personnel, client, produit) pour mieux les protéger.	Données	Identifier	IG 1/2/3	3 - Intermédiaire		
	3	3.3	Configurer les listes de contrôle d'accès aux données.	Configurer les droits d'accès pour que les employés n'aient accès qu'à leurs données nécessaires à leur fonction.	Données	Protéger	IG 1/2/3	2 - Émergent		
	3	3.4	Appliquer la politique de conservation des données.	Appliquer des règles automatisées pour conserver ou détruire les données selon les exigences légales et métier.	Données	Protéger	IG 1/2/3	4 - Confirmé		
	3	3.5	Supprimer les données de manière sécurisée.	Mettre en place un effacement cryptographique ou une destruction physique soignée pour les supports en fin de vie.	Données	Protéger	IG 1/2/3	3 - Intermédiaire		

Choix du niveau de maturité

Pour chaque exigence, l'utilisateur doit sélectionner un niveau de maturité à l'aide d'un menu déroulant. Les niveaux proposés permettent d'évaluer l'état d'application de la mesure. Le choix du niveau modifie automatiquement la signification associée, la couleur de la cellule et les statistiques des tableaux de bord. Exemple de niveaux utilisés :

- 1 – Insuffisant
- 2 – Émergent
- 3 – Intermédiaire
- 4 – Confirmé
- 5 – Optimal
- Non applicable

The screenshot shows a table with maturity levels and descriptions. A dropdown menu is open for the first row, showing options from 1 to 5 and 'Non applicable'. Three callouts are present:

- 1 Cliquer sur la cellule**: Points to the first row's maturity level cell.
- 2 Choisir le niveau adapté**: Points to the dropdown menu.
- 3 La couleur et la description se mettent à jour automatiquement**: Points to the description text in the first row, which changes based on the selected maturity level.

5 - Optimal	Des objectifs de réduction des risques cyber intégrés à la stratégie de l'organisation. Des moyens humains, budgétaires conséquents, un plan d'action cyber exhaustif, adapté aux menaces stratégiques.
1 - Insuffisant	Une prise de conscience de l'existence de risques cyber pour l'organisation et une volonté de mettre en place des premières mesures cyber pertinentes.
2 - Émergent	Une prise de conscience de l'existence de risques cyber pour l'organisation, un plan d'action cyber précis de ses risques cyber pour l'organisation, un plan d'action cyber exhaustif, adapté aux menaces stratégiques.
3 - Intermédiaire	Une cartographie précise de ses risques cyber pour l'organisation, un plan d'action cyber approfondi et des moyens humains et budgétaires dédiés.
4 - Confirmé	
5 - Optimal	Des objectifs de réduction des risques cyber intégrés à la stratégie de l'organisation. Des moyens humains, budgétaires conséquents, un plan d'action cyber exhaustif, adapté aux menaces stratégiques.

Échelle de maturité

La feuille Échelle de maturité explique la signification des différents niveaux utilisés dans l’outil. Elle sert de référence pour aider l’utilisateur à choisir un niveau cohérent. Elle permet aussi d’harmoniser les évaluations entre les différents référentiels. L'utilisateur doit se référer à cette feuille lorsqu'il hésite entre deux niveaux de maturité.

1 Niveau de maturité

2 Signification

Niveaux de Maturité	Signification	Libellé	Code couleur
1	Une conscience insuffisante des risques cyber pesant sur l'organisation. Pas ou peu de mesures spécifiques mises en oeuvre en matière de cybersécurité.	1 - Insuffisant	
2	Une prise de conscience de l'existence de risques cyber pour l'organisation et une volonté de mettre en place des premières mesures cyber pertinentes.	2 - Émergent	
3	Une conscience partagée des risques cyber pour l'organisation et la volonté de formaliser un plan d'action cyber complet tout en ajustant les moyens en conséquence.	3 - Intermédiaire	
4	Une cartographie précise de ses risques cyber pour l'organisation, un plan d'action cyber approfondi et des moyens humains et budgétaires dédiés.	4 - Confirmé	
5	Des objectifs de réduction des risques cyber intégrés à la stratégie de l'organisation. Des moyens humains, budgétaires conséquents, un plan d'action cyber exhaustif, adapté aux menaces stratégiques.	5 - Optimal	
NA	Le critère ou l'exigence évalué n'est pas pertinent au regard des activités, du périmètre technique ou du cadre réglementaire de l'organisation.	Non applicable	

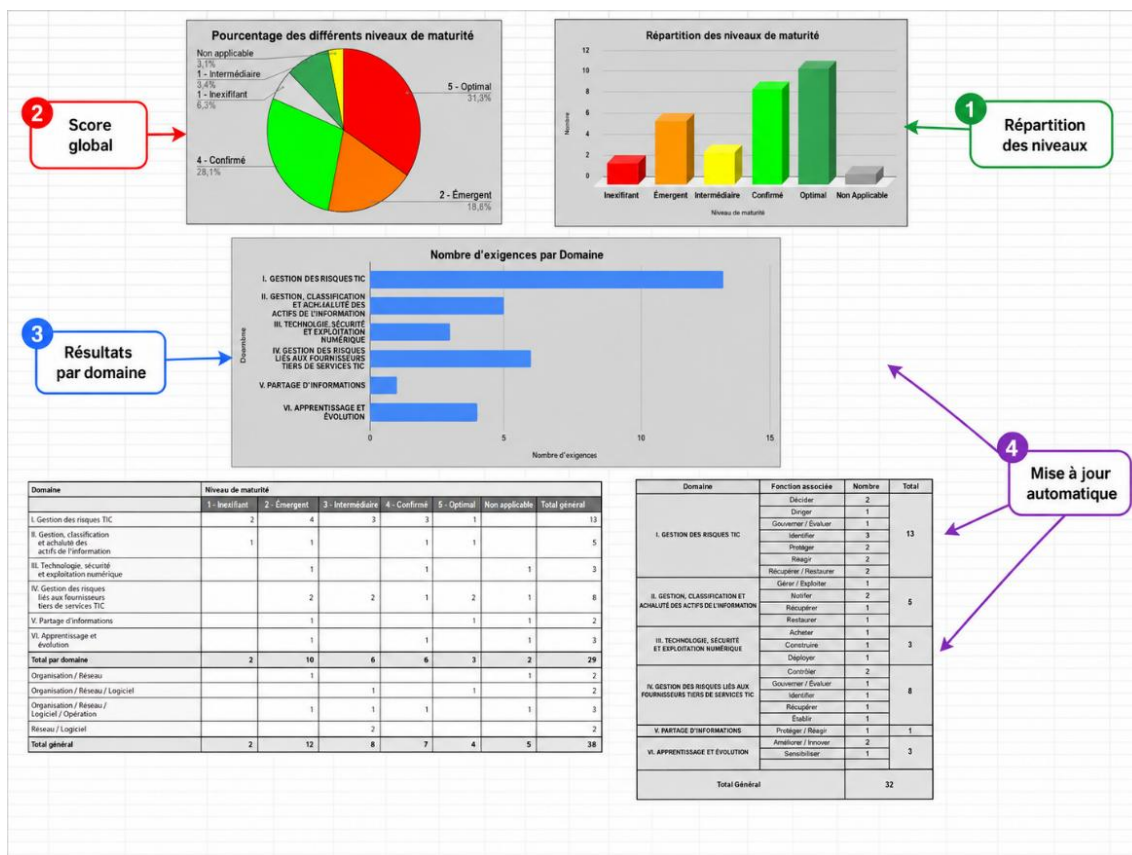
3 Aide au choix du niveau

Tableaux de bord et interprétation des résultats

Les feuilles Dashboard permettent de visualiser automatiquement les résultats de l'évaluation. Elles peuvent contenir :

- La répartition en pourcentage des niveaux de maturité ;
- Le nombre d'exigences par niveau ;
- Le score global ;
- Les résultats par domaine ;
- Les graphiques de répartition ;
- Les axes d'amélioration.

Ces tableaux de bord se mettent à jour automatiquement lorsque l'utilisateur modifie les niveaux de maturité dans les feuilles de référentiel.



Conclusion du guide

Ce manuel présente les principales étapes d'utilisation de l'outil d'évaluation de maturité SSI. L'utilisateur commence par choisir le référentiel adapté, consulte les exigences, sélectionne les niveaux de maturité, ajoute des commentaires si nécessaire, puis analyse les résultats dans les tableaux de bord. L'outil permet ainsi de comparer différents cadres de cybersécurité, d'identifier les points faibles et de prioriser les actions d'amélioration. Les quatre référentiels intégrés dans l'outil sont complémentaires :

- l'ANSSI apporte des bonnes pratiques concrètes ;
- DORA cible la résilience numérique du secteur financier ;
- NIS2 encadre la cybersécurité des entités essentielles et importantes ;
- Les CIS Controls proposent des contrôles opérationnels prioritaires.